SECURITY



Beyond Static Identity: Enabling Secure Certificate Refresh in Silicon Roots of Trust

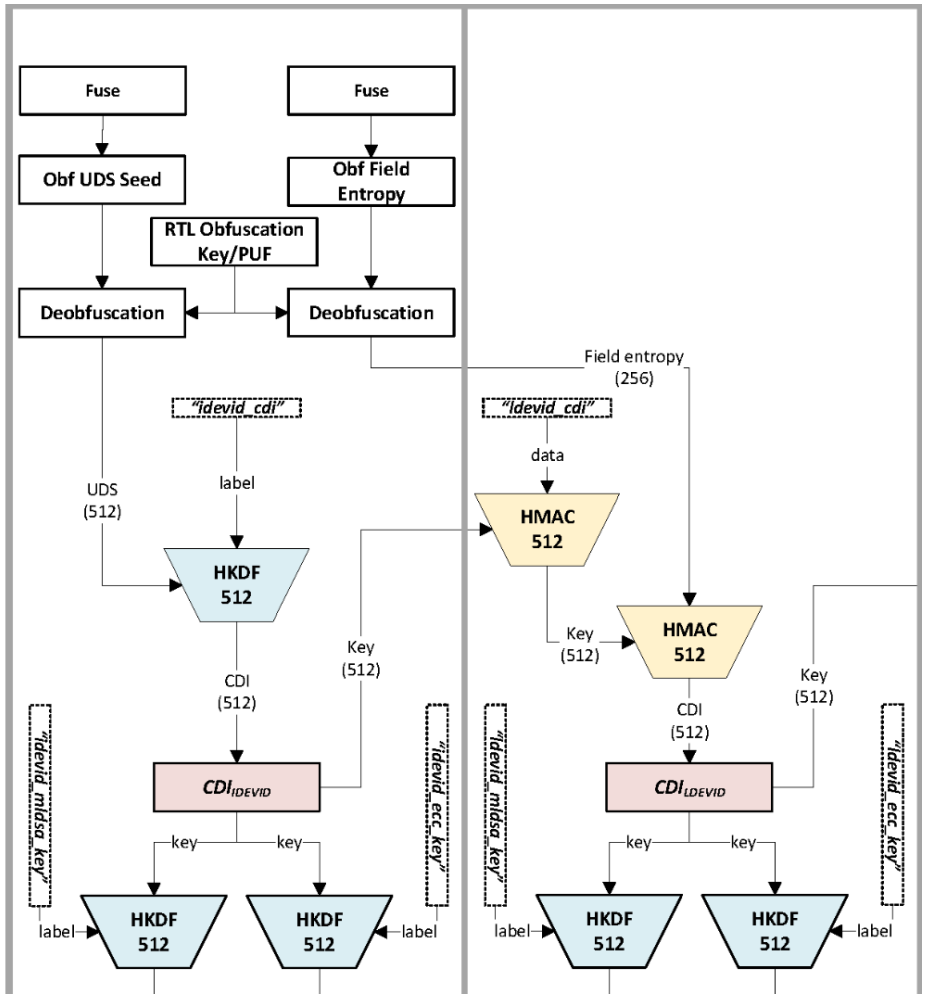


Emre Karabulut *Sr. Security Architect, Microsoft*

Vishal Mhatre *Principal FW Engineer, Microsoft*

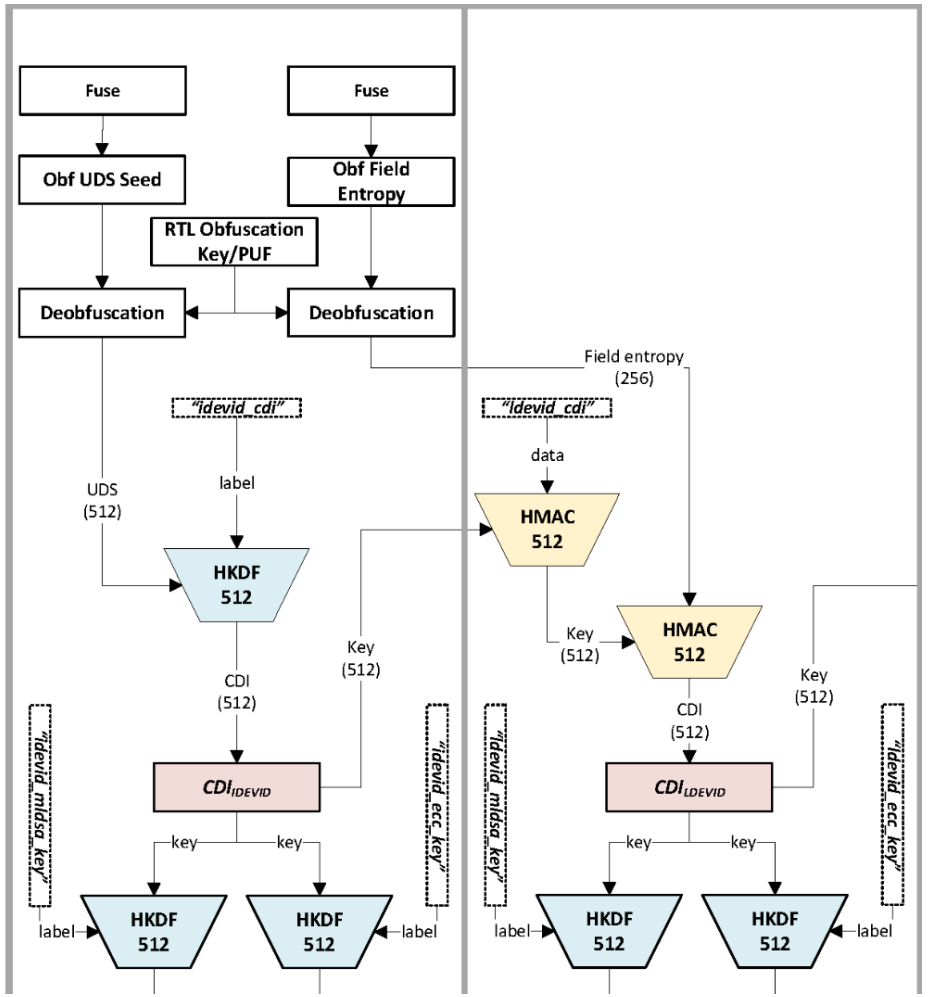
Current FE Fuses & LDevID CDI

- Four 64-bit field-entropy fuses
- 256 bits total — but consumed as one block
- If we do not trust the secrets coming from manufacturer:
  - UDS is known
  - DOE key is known
- Full 256-bit FE is needed at once — collision probability is 2^{128}
- The FE is stored in fuses, so:
  - The certificate cannot be renewed



Refurbishment Requirements

- No customer data may remain in the refurbishment center
- UDS and FE — or at minimum FE — must be zeroized
  - Production chips already ship with UDS + DOE key present, so leaving them follows the same threat model
- We must be able to re-provision a new FE CDI
- Stable key generation flows must rely on FE CDI to generate a stable secret key



Certificate Renewal vs. Refurbishment

Refurbishable Device

- FE must be zeroized
- FE should be re-provisionable
- UDS CDI cannot be used in any secret-key generation
- Not supported with Caliptra 2.x

Certificate-Renewable Only

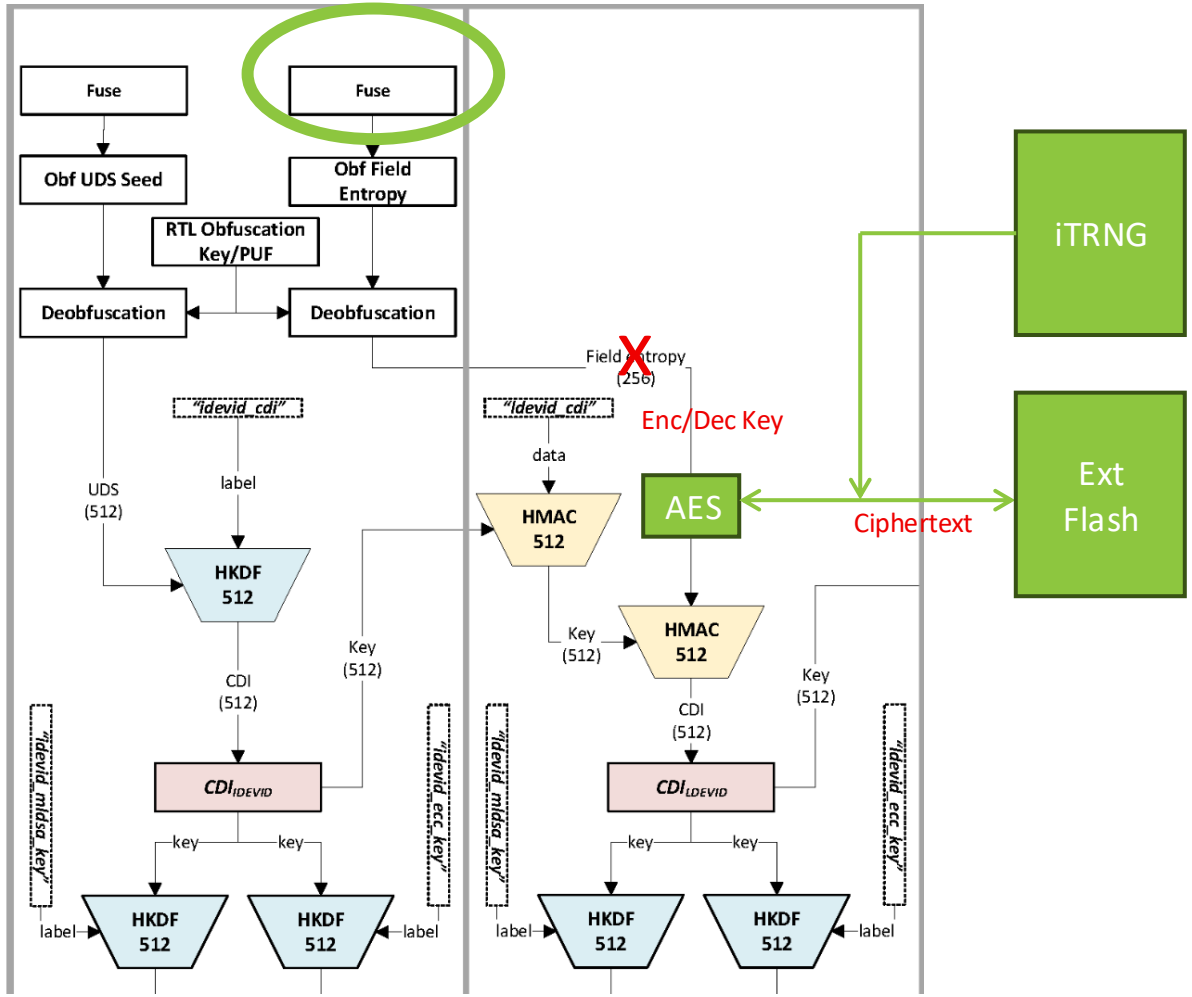
- FE does not need to be zeroized
- FE must be re-provisioned
- UDS may be used if enriched with an extra secret the vendor never provisioned
- Not supported with Caliptra 2.x

Reuse FE Fuses as an AES Key

- Reuse the existing FE fuses as an AES encryption key
- Each provisioning draws a fresh iTRNG sample
- Ciphertext is stored in flash

Problems

- Flash is not reliable long-term storage
- No secure channel — re-certification is easy to force
- Refurbishment still needs a new AES key provisioned

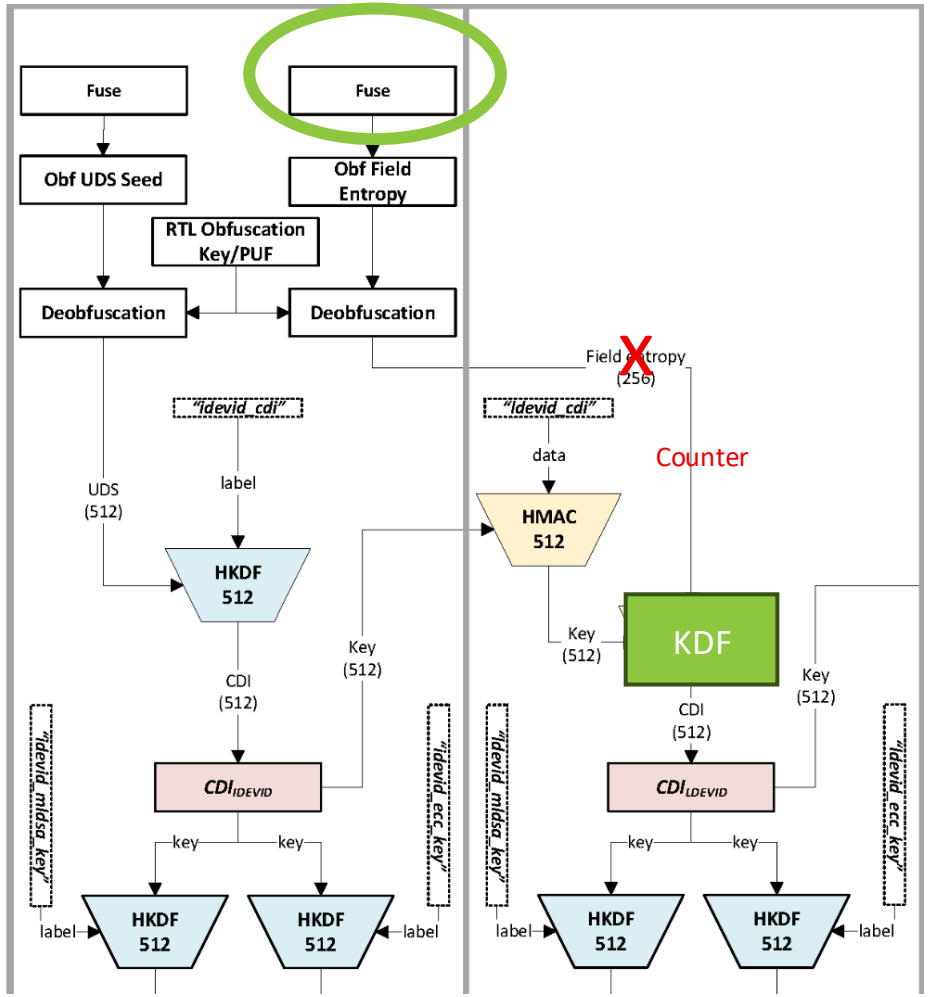


Reuse FE Fuses as “Counter” in KDF

- If we trust the secrets provisioned at manufacturing:
  - We can solve the re-certification with fewer fuse bits
- Derive the LDevID CDI with an SP-800-108 KDF in counter mode

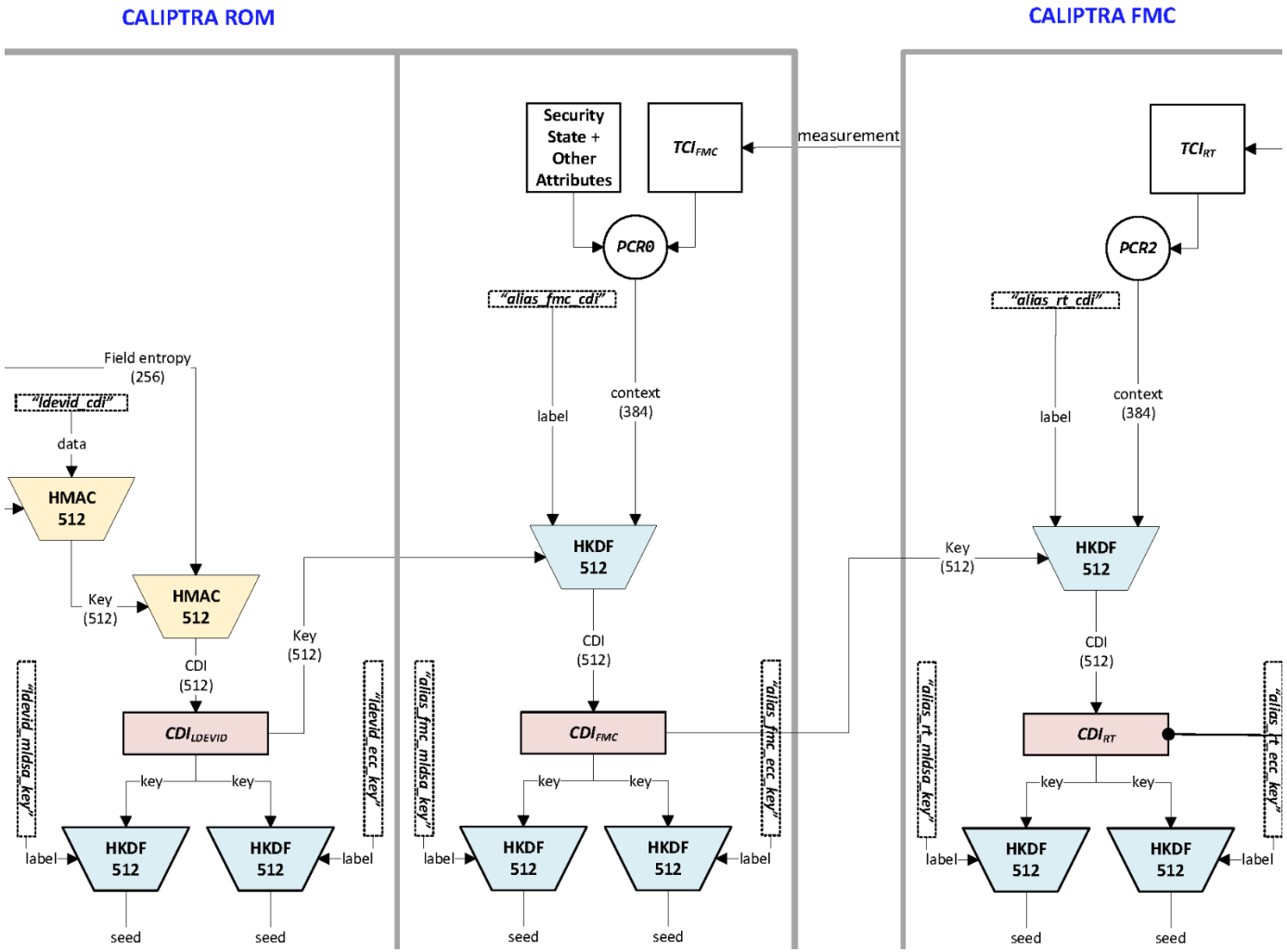
SP-800-108 KEY DERIVATION

```
K(i) := PRF ( KI, [i] || Label || 0x00 || Context || [L] )
```



Generate the FE Certificate in FMC After the FMC Alias Certificate

- Caliptra ROM space is constrained; move certificate generation out of ROM
- Generate the LDevID certificate in FMC, after the FMC Alias certificate
- Bind the KDF to the FMC PCR
- Include the HW or FMC version in the refurbishment flow
- Use external flash when fuse capacity is limited



Call to Action

- Problem to solve
  - Refreshing device identity over time without compromising security or exposing secrets
- This solution:
  - Introduces an identity generation:
    - From hardware-originated secrets
    - Ensuring that no sensitive material is exposed outside the device
    - Need no external trust anchors are required at runtime
- We still need more reliable storage mechanism to compete with eFuses
- Where to find additional information (URL links)
  - Where to get more info: Caliptra/doc/Caliptra.md at main · chipsalliance/Caliptra
  - Where to get the implementation: https://github.com/chipsalliance/caliptra-sw
  - HW implementation link: https://github.com/chipsalliance/caliptra-ss

Thank You!

